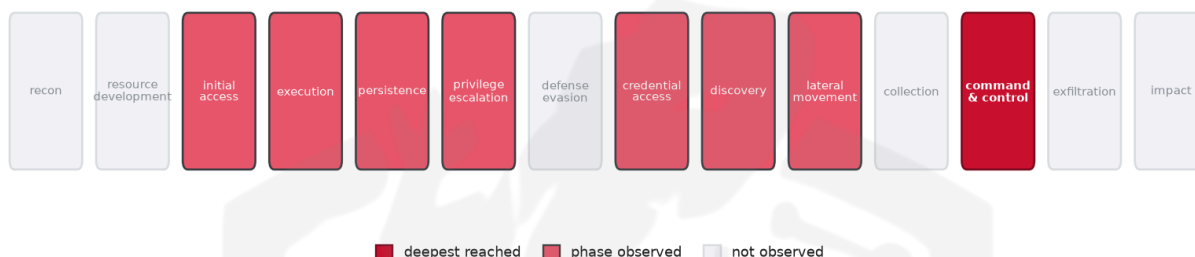


THREAT REPORT: UNKNOWN_ADVERSARY

NADMESH BOTNET

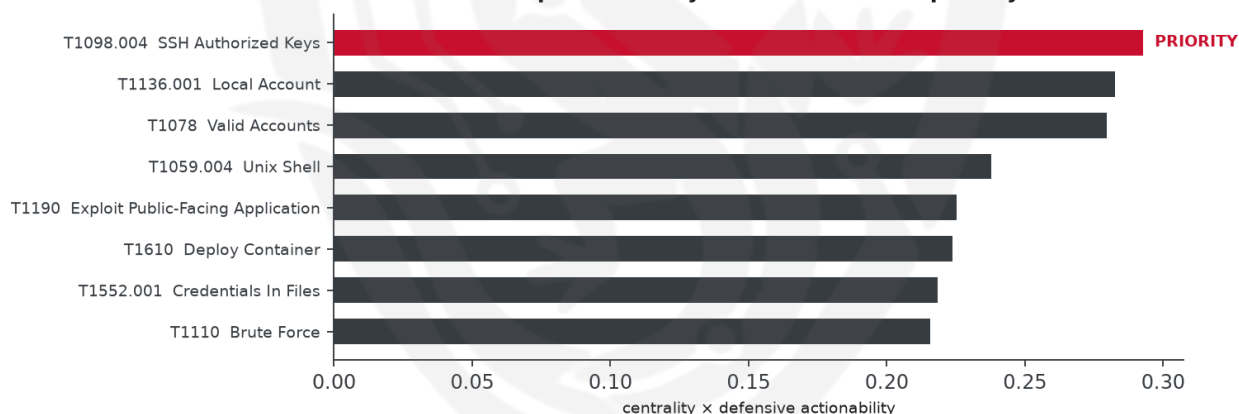
Visual Summary

Kill-Chain Reach — High (deepest phase reached: command-and-control)



How far down the attack chain this campaign reached; deepest phase in crimson.

Defensive Chokepoint — why this control is the priority



The control that most disrupts the attack (priority in crimson).

Summary

The observed cluster of activity has been linked to the NadMesh malware family, which exploits the CVE-2016-0638 vulnerability, primarily targeting the technology sector. The threat actor's identity and targeted country remain unknown. Priority should be given to patching the exploited vulnerability and monitoring for suspicious account activity. The operational risk band for this threat is considered high, indicating a significant potential impact.

Threat Overview

The threat actor, referred to here as the observed cluster of activity, utilizes the NadMesh malware family to exploit the CVE-2016-0638 vulnerability. The victimology of this threat is focused on the technology sector, although specific details on targeted countries are insufficient. The malware's techniques include

various methods for remote access, system information discovery, and exploit of public-facing applications.

Attack Chain and Priority Control

The observed techniques form a complex chain, starting with external remote services and progressing through system information discovery, exploit of public-facing applications, and finally, establishing command-and-control. The priority technique identified is T1098.004 SSH Authorized Keys, which serves as a critical chokepoint in the attack chain. To mitigate this threat, the recommended priority control is to: Patch CVE-2016-0638 on all affected systems as the top priority, then: Alert on privilege/group changes and credential additions to accounts (Event ID 4738/4670); review conditional-access changes.

Infrastructure and Corroboration

The malicious infrastructure associated with this threat has been observed to be hosted by SKN Subnet & Telecom Ltd. While there are no malware families corroborated by abuse.ch, AbuseIPDB has flagged some indicators with a confidence level of up to 68%, although none reach the 80% confidence threshold. These findings are based on third-party enrichment and serve to corroborate the source pulse without overriding its assessments.

Technical Appendix

Ground-truth telemetry from the source pulse; analytical scores are secondary and clearly labelled.

Observed Techniques (ATT&CK, expert-tagged by source)

- T1133 External Remote Services
- T1053.003 Cron
- T1021.004 SSH
- T1082 System Information Discovery
- T1190 Exploit Public-Facing Application
- T1611 Escape to Host
- T1610 Deploy Container
- T1136.001 Local Account
- T1098.004 SSH Authorized Keys
- T1552.001 Credentials In Files
- T1110 Brute Force
- T1059.004 Unix Shell
- T1078 Valid Accounts
- T1027.002 Software Packing
- T1071.001 Web Protocols
- T1046 Network Service Discovery
- T1105 Ingress Tool Transfer
- T1078.004 Cloud Accounts

- T1552.007 Container API

Analytical Scores

- Priority technique (graph chokepoint): T1098.004 SSH Authorized Keys (centrality 0.3082).
- Operational risk: High (score 0.636, reaches command-and-control).

Behavioral Signature Cluster

- Method: technique-overlap cosine vs 170 MITRE ATT&CK Groups (top overlap 0.4529; reference threshold $\tau = 0.6$).
- These are behavioural resemblances for defensive playbook cross-referencing, not an identity assessment. Where the source pulse names an actor, that attribution is authoritative; the overlaps below neither confirm nor contest it.

Nearest historical profiles by behavioural overlap (resemblance only):

Historical Profile	Behavioural Overlap
TeamTNT	0.4529
Rocke	0.416
APT18	0.416
FIN13	0.385
Fox Kitten	0.3736

Enrichment Signal

- Highest AbuseIPDB confidence among IOCs: 68%.

Indicators of Compromise (defanged — non-clickable)

The network and file indicators observed in this activity are listed below for blocklisting:

Type	Indicator	Context
IP	209[.]99[.]186[.]235	AbuseIPDB 68% (CH) · AS402253 SKN Subnet & Telecom Ltd
Domain	cdnorigin[.]net	
Hash	ca024acead8f54cfe5b07ac4bdf7fcea	
Hash	31c69b3e12936abca770d430066f379ec1d997ec	

Type	Indicator	Context
Hash	fc4109f5dd1d30b65dd60e57dc639ac1d313bfa5241e36 e61fbc4aabc1cda482	

Reputation by AbuseIPDB · malware attribution by abuse.ch · Geo/ASN data by IP2Location LITE.

Flame Cell // Adversary Pivot [BETA]

BETA. A hypothetical tabletop projection, anchored to documented ATT&CK behaviour and technique co-occurrence across 170 tracked groups. It is not a prediction; treat it as a war-game prompt and review before acting. Spot a pivot that looks wrong? norbert@salacti.com

- **Control applied:** T1098.004 SSH Authorized Keys (persistence)
- **Observed here:** the threat actor used T1078 Valid Accounts here as an alternative persistence technique.
- **Projected pivot:** T1078 Valid Accounts (persistence)
- **Basis:** observed in this campaign (an alternative the actor already demonstrated).

The actor could pivot to using T1078 Valid Accounts by exploiting existing credentials to maintain access and achieve their objectives, potentially leveraging compromised accounts that were not dependent on SSH authorized keys. This technique may allow the actor to blend in with normal user activity, making it more challenging to detect their presence. The defensive control to counter this would be to Enforce MFA on all accounts; disable dormant and over-privileged accounts; alert on impossible-travel and anomalous logons.

Detection and hardening for the pivot (T1078 Valid Accounts)

- **Telemetry:** Windows Security (logon events); Azure AD / IdP sign-in logs; VPN and remote-access logs; Proxy / DLP / data-egress volume telemetry
- **Detect:**
 - Security 4624/4625 (logon success/fail), 4768/4769 (Kerberos TGT/TGS), 4776 (NTLM)
 - Impossible-travel, new-geo, and off-hours sign-ins from the IdP
 - Service or dormant accounts logging on interactively
 - Under valid credentials the identity signal goes quiet: baseline per-account data-egress volume and alert on peer-group and historical deviation (the real exfiltration tell)
- **Harden:**
 - Enforce MFA everywhere; disable stale accounts; rotate exposed credentials
 - Least-privilege review; separate admin from daily-driver accounts
 - Set per-account and per-partner egress baselines with DLP thresholds on sensitive stores
- **MITRE:** M1032 Multi-factor Authentication, M1026 Privileged Account Management, M1027 Password Policies, M1018 User Account Management · DS0028 Logon Session, DS0002 User Account